

Modelo de Encuesta Integral

Pirámide del Dolor, Indicadores y Métricas de Detección

Encuesta dirigida a responsables de seguridad, riesgo, TI y continuidad de negocio.

El objetivo es medir en qué medida su organización hace daño “del bueno” al adversario, no sólo colecciona hashes como si fueran cromos.

1. Información general de la organización

1.1 Tipo de organización (marque todas las que apliquen):

- Administración pública (estatal)
- Administración pública (autonómica)
- Administración pública (local)
- Operador de servicios esenciales (OES)
- Operador de servicios críticos / infraestructuras críticas
- Empresa privada (gran empresa, >250 empleados)
- Empresa privada (mediana, 50–250 empleados)
- Pyme (<50 empleados)
- Proveedor de servicios gestionados (MSSP / MDR / SOC)
- Otro (especifique): __

1.2 Sector principal de actividad:

- Salud
- Energía
- Agua
- Transporte y logística
- Finanzas / seguros
- Industria / manufactura
- TIC / telecomunicaciones
- Administración pública
- Educación / investigación
- Otros servicios
- Otro (especifique): __

1.3 Rol del/de la respondente:

- CISO / Responsable de Seguridad de la Información
- Responsable de Ciberseguridad (sin título formal de CISO)
- Responsable de TI / Infraestructuras
- Responsable de Riesgos / Cumplimiento
- Responsable de Continuidad de Negocio / Resiliencia
- Dirección General / Consejo
- Otro (especifique): __

1.4 Número aproximado de empleados de la organización:

- <50
- 50–249
- 250–999
- 1.000–4.999
- ≥5.000

1.5 ¿Dispone la organización de un SOC (interno o externo)?

- Sí, SOC interno 24x7
- Sí, SOC interno parcial (horario de oficina / híbrido)
- Sí, SOC externo (MSSP/MDR)
- No, pero está en proyecto
- No, ni se le espera (por ahora)

2. Marco conceptual y uso de la Pirámide del Dolor

2.1 Antes de esta encuesta, ¿había oído hablar de la “Pirámide del Dolor” de David Bianco?

- Sí, la conozco bien y la utilizamos
- Sí, la conozco superficialmente
- He oído el término, pero no sabría dibujarla sin ayuda
- No, es la primera vez que oigo hablar de ella

2.2 En su organización, la Pirámide del Dolor se utiliza principalmente como:

- Referencia explícita para diseñar detecciones
- Referencia conceptual en formaciones / presentaciones
- Complemento de otros marcos (MITRE ATT&CK, NIST, etc.)
- Curiosidad teórica que aparece en algún PPT
- No se utiliza en absoluto

2.3 ¿Existe algún documento interno (política, estándar, guía) donde la Pirámide del Dolor se mencione explícitamente?

- Sí, en políticas o estándares formales
- Sí, en guías técnicas o runbooks del SOC
- Sólo en materiales de formación interna
- No
- No lo sé

2.4 ¿Con qué frecuencia se revisa el modelo de indicadores a la luz de la Pirámide del Dolor (o marcos equivalentes)?

- Al menos una vez al año
- Cada 2–3 años
- Ad hoc, cuando ocurre algún incidente reseñable
- Nunca se ha revisado formalmente
- No lo sé

3. Indicadores de bajo nivel: hashes, direcciones IP, dominios

3.1 Respecto a hashes de archivos maliciosos, su organización:

- Mantiene un repositorio estructurado y etiquetado (por campaña, familia, TTP asociada, etc.)
- Almacena hashes, pero sin enriquecimiento sistemático
- Utiliza mayoritariamente feeds externos, sin repositorio propio
- Bloquea hashes “al vuelo” sin apenas registro
- No trabaja con hashes de forma explícita

3.2 ¿Cuál es el origen principal de los hashes que se utilizan para detección/bloqueo?

- Feed interno de análisis de malware
- Feeds de CERT/CSIRT nacionales (p. ej., INCIBE-CERT, CCN-CERT)
- Feeds comerciales (proveedores de seguridad)
- Feeds de la comunidad / intercambio sectorial
- Los genera el SOC / equipo interno según incidentes
- No se dispone de información al respecto

3.3 ¿Miden el tiempo transcurrido entre la primera observación de un hash malicioso y su distribución/bloqueo en sus sistemas?

- Sí, de forma automatizada y con indicadores periódicos
- Sí, pero sólo en análisis post-incidente
- No, pero sería deseable
- No, y no está previsto

3.4 En términos de valor operativo, ¿cómo describiría el papel de los hashes en su estrategia de detección?

- Crítico: base de muchas detecciones efectivas
- Importante, pero complementado por otras capas
- Útil sobre todo para forense, no tanto para detección proactiva
- Marginal: casi todo se mueve ya a comportamiento / TTP
- Desconozco su relevancia real

3.5 Respecto a direcciones IP maliciosas, su organización:

- Mantiene listas dinámicas con depuración periódica y TTL definido
- Conserva listas que crecen casi indefinidamente
- Depende fundamentalmente de listas externas (ISP, proveedores, CERT)
- Aplica bloqueos temporales sin gestión posterior
- No realiza gestión específica de IP maliciosas

3.6 ¿Miden la “vida útil” de las IP maliciosas que bloquean (es decir, cuánto tiempo siguen siendo relevantes)?

- Sí, mediante telemetría y análisis histórico
- Parcialmente, para ciertos tipos de incidentes

- No, sólo se bloquean y ya
- No, y no se considera prioritario

3.7 En cuanto a dominios maliciosos (DGAs, phishing, C2, etc.), indique el grado de sistematización:

- Se gestionan con listas gestionadas, categorizadas y con caducidad explícita
- Se gestionan, pero con mantenimiento básicamente manual
- Se consumen principalmente feeds de terceros (DNS, proxies, etc.)
- Se actúa caso a caso según incidentes
- No existe una práctica definida

3.8 ¿Existe una política formal sobre la caducidad y revisión de IoC de bajo nivel (hashes, IP, dominios)?

- Sí, formalizada y revisada al menos anualmente
- Sí, pero no se revisa de forma sistemática
- Sólo prácticas informales
- No existe tal política
- No lo sé

4. Artefactos de red y host

4.1 ¿Su organización dispone de detecciones específicas basadas en patrones de tráfico de red (no sólo IP/dominios)?

- Sí, de forma amplia (IDS/IPS, NDR, reglas a medida, etc.)
- Sí, pero limitadas a firmas de proveedor
- Algunas reglas específicas desarrolladas internamente
- Predominan las reglas basadas en IoC simples
- No disponemos de detecciones de ese tipo

4.2 En el plano de endpoint/host, ¿qué sistemas se utilizan?

- EDR/XDR con reglas personalizadas propias
- EDR/XDR con reglas principalmente del fabricante
- Antimalware tradicional con alguna personalización
- Herramientas básicas (antivirus, firewall local)
- No se dispone de soluciones específicas en endpoints

4.3 ¿Se etiqueta cada regla de red/host con algún nivel de la Pirámide del Dolor (o equivalente)?

- Sí, usamos explícitamente la Pirámide del Dolor
- Sí, usamos otra taxonomía de “profundidad” o “robustez” de detección
- No, pero se distingue informalmente entre reglas “simples” y “complejas”
- No, todas las reglas se gestionan a mismo nivel
- No lo sé

4.4 En incidentes significativos del último año (ransomware, brechas de datos, etc.), ¿se ha medido cuántas alertas de artefactos de red/host se generaron antes del impacto?

- Sí, de forma sistemática y documentada

- Sí, en análisis post-mortem de casos graves
- Puntualmente, a iniciativa de algún analista entusiasta
- No, no se ha medido
- No se han registrado incidentes de este tipo (que se sepa)

4.5 ¿Existe algún indicador regular del tipo “porcentaje de incidentes críticos donde hubo alertas de artefactos previas utilizables”?

- Sí, es un KPI formal
- Se calcula, pero sin formalización como KPI
- No, aunque sería muy útil
- No, y no está previsto

4.6 ¿Con qué frecuencia se revisan y ajustan las reglas basadas en artefactos (red/host)?

- Al menos mensualmente
- Trimestralmente
- Anualmente
- Sólo tras incidentes relevantes
- Prácticamente nunca (si funciona, no lo toques)

5. Herramientas del adversario y TTP (MITRE ATT&CK)

5.1 ¿Utilizan MITRE ATT&CK (u otros marcos de TTP) de forma estructurada?

- Sí, contamos con una matriz ATT&CK específica de la organización
- Sí, pero de forma parcial o por campañas concretas
- Conocemos ATT&CK, pero no está integrado en procesos
- No, no utilizamos ATT&CK de forma práctica
- No lo sé

5.2 Si utilizan ATT&CK, ¿para qué se utiliza principalmente?

- Diseñar y mapear reglas de detección
- Analizar incidentes y hacer threat hunting
- Priorizar inversiones en seguridad
- Formación del personal
- Sólo como referencia “inspiradora”
- No aplicable (no usamos ATT&CK)

5.3 ¿Se realiza un seguimiento sistemático de qué técnicas ATT&CK se han observado en incidentes reales en la organización?

- Sí, con registro y estadísticas periódicas
- Sí, pero sólo en casos graves
- Se hace de forma irregular
- No, no se realiza
- No lo sé

5.4 ¿Dispone de métricas de cobertura ATT&CK para sus detecciones? (por ejemplo, porcentaje de técnicas relevantes para su sector con al menos una detección asociada)

- Sí, métricas cuantificadas y revisadas periódicamente
- Parcialmente, para ciertos ámbitos (p. ej., APT, OT, etc.)
- Se ha intentado, pero sin sistematización
- No, no se dispone de ese tipo de métricas
- No lo sé

5.5 ¿Etiqueta las reglas de detección según el nivel de la Pirámide al que apuntan (hash/IP/dominio vs artefacto vs TTP)?

- Sí, a nivel global
- Sí, en algunas plataformas o tecnologías
- No, pero podría hacerse con relativo esfuerzo
- No, requeriría reingeniería profunda
- No lo sé

5.6 En términos de inversión de esfuerzo de los equipos de detección, ¿qué proporción aproximada se dedica a:

- a) IoC de bajo nivel
- b) Artefactos de red/host
- c) TTP / comportamiento adversario?

- Predominan IoC de bajo nivel (>60%)
- Distribución equilibrada entre los tres niveles
- Se priorizan claramente TTP / comportamiento
- Desconozco la distribución aproximada

5.7 ¿Realizan ejercicios específicos para “elevar” detecciones de niveles bajos (hash/IP) a niveles superiores (artefactos/TTP)?

- Sí, es parte de la mejora continua del SOC
- Sí, pero de forma ad hoc
- Se ha discutido, pero no se aplica
- No, no se contempla
- No lo sé

6. Métricas de tiempo, eficacia y “dolor infligido”

6.1 ¿Miden el tiempo medio de detección (MTTD) y el tiempo medio de respuesta (MTTR) en incidentes?

- Sí, de forma sistemática con paneles y reportes
- Sí, pero sólo para incidentes graves
- Parcialmente, con datos poco consistentes
- No, no se mide
- No lo sé

6.2 ¿Diferencian estos tiempos según el nivel de la Pirámide en el que se produjo la primera detección?

- Sí, de forma explícita
- Parcialmente, por tipo de alerta (aunque no se hable de pirámide)
- No, todos los incidentes se miden igual
- No se dispone de datos

6.3 ¿Calculan la reducción de ataques exitosos atribuible a detecciones de alto nivel (artefactos/TTP) frente a IoC simples?

- Sí, con métricas y análisis comparativos
- Aproximadamente, mediante estudios internos puntuales
- No, aunque sería interesante
- No, y no está entre los objetivos actuales

6.4 ¿Existe alguna estimación del ahorro de tiempo de analistas gracias a detecciones mejor diseñadas (menor ruido, mayor contexto)?

- Sí, cuantificada en horas o equivalentes FTE
- Estimaciones cualitativas, sin cifras concretas
- No se ha intentado calcular
- No lo sé

6.5 ¿Qué porcentaje aproximado de las alertas recibidas considera “ruido” (falsos positivos o de poca utilidad)?

- <10%
- 10–30%
- 30–60%
- >60%
- No se ha medido / no se sabe

6.6 ¿Se revisan las reglas con más falsos positivos para “elevarlas” en la Pirámide (pasar de IoC trivial a comportamiento más preciso)?

- Sí, como parte de un proceso formal de tuning
- A veces, según la disponibilidad del equipo
- Rara vez se revisan
- Prácticamente nunca
- No lo sé

6.7 En términos generales, ¿cómo valoraría la capacidad actual de su organización para “hacerle daño real” a un adversario sofisticado (es decir, obligarle a cambiar procesos, herramientas o TTP)?

- Alta: sabemos dónde presionar para que duela
- Media: incomodamos, pero no desbaratamos campañas
- Baja: más reacción que disuasión
- Muy baja: somos espectadores más que actores
- Prefiero no pronunciarme

7. Gobernanza, coordinación y ámbito nacional

7.1 ¿Su organización comparte indicadores (en cualquier nivel de la Pirámide) con organismos nacionales o sectoriales (CERT, CSIRT, centros de intercambio)?

- Sí, de forma estructurada y periódica
- Sí, pero sólo en incidentes relevantes
- De forma puntual, sin proceso formal
- No se comparte información
- No lo sé

7.2 ¿Qué tipos de indicadores comparte con más frecuencia?

- IoC de bajo nivel (hashes, IP, dominios)
- Artefactos de red/host (reglas, patrones)
- TTP, playbooks de adversario, herramientas usadas
- Información contextual (impacto, sector, vulnerabilidades explotadas)
- No compartimos información

7.3 ¿Recibe de organismos nacionales/sectoriales indicadores diferenciados por niveles de la Pirámide?

- Sí, claramente clasificados
- Parcialmente, según el emisor
- Recibimos IoC, pero sin clasificación avanzada
- Recibimos avisos muy generales
- No recibimos información específica

7.4 ¿Integran estos indicadores externos en sus métricas internas (MTTD, MTTR, eficacia de detección)?

- Sí, se correlacionan y analizan de forma sistemática
- Sólo para algunos tipos de incidentes
- Se integran de forma manual y puntual
- No, se utilizan sólo como referencia cualitativa
- No lo sé

7.5 ¿Existe alguna coordinación con otras organizaciones similares (sector, grupo empresarial, clúster) para mejorar de forma conjunta detecciones de alto nivel (TTP, comportamiento)?

- Sí, grupos de trabajo activos y recurrentes
- Sí, pero de forma informal
- Se ha intentado, sin continuidad
- No, no existe tal coordinación
- No lo sé

8. Normativa, cumplimiento y alineación con marcos externos

8.1 ¿Qué marcos/regulaciones influyen principalmente en su estrategia de detección y métricas? (marque todas las que apliquen)

- NIS2 / normativa europea de ciberseguridad
- RGPD / normativa de protección de datos

- Esquema Nacional de Seguridad (ENS)
- Normas ISO (27001, 22301, etc.)
- Sectoriales (DORA, NERC CIP, etc.)
- Otras (especifique): __

8.2 ¿Existe alguna referencia explícita en sus políticas a la necesidad de detección basada en comportamiento/TTP?

- Sí, recogida claramente
- Implícita, pero no mencionando TTP
- No, se habla genéricamente de “detección de amenazas”
- No lo sé

8.3 ¿Se reportan métricas de detección y respuesta al Consejo de Administración o alta dirección?

- Sí, regularmente (al menos trimestralmente)
- Sólo tras incidentes significativos
- De forma esporádica
- No se reportan métricas de este tipo
- No lo sé

8.4 En esos reportes, ¿se diferencia entre detecciones “superficiales” (IoC) y “profundas” (TTP, comportamiento)?

- Sí, de forma explícita
- Se insinúa, pero sin nomenclatura formal
- No, todo se presenta agregado
- No lo sé

9. Visión, retos y próximos pasos

9.1 ¿Cuál considera que es el principal obstáculo para adoptar plenamente una estrategia basada en la Pirámide del Dolor?

- Falta de recursos humanos especializados
- Limitaciones presupuestarias
- Complejidad técnica / legado
- Falta de apoyo de la alta dirección
- Falta de coordinación con terceros (proveedores, autoridades)
- Falta de visibilidad / telemetría adecuada
- Otros (especifique): __

9.2 ¿Qué tipo de apoyo externo considera más útil para avanzar?

- Guías metodológicas y buenas prácticas
- Herramientas y automatización
- Servicios de SOC/MDR avanzados
- Programas de formación / capacitación

- Plataformas de intercambio de información

- Otros (especifique): __

9.3 En una escala del 1 al 5, ¿cuánta prioridad cree que debería tener, en los próximos 2 años, la mejora de detecciones de alto nivel (TTP, comportamiento) en su organización?

- 1 – Prioridad muy baja

- 2 – Prioridad baja

- 3 – Prioridad media

- 4 – Prioridad alta

- 5 – Prioridad máxima

9.4 Por último, si pudiera enviarle un mensaje breve a su “yo del futuro” como responsable de seguridad, sobre la Pirámide del Dolor, ¿qué le diría?

- Respuesta abierta: _____

Gracias por su tiempo y sinceridad. Si en algún momento ha sentido un ligero cosquilleo de incomodidad, la encuesta ha cumplido su función.